

09 Catalogo de API SaborExpress

SABOREXPRESS — PROYECTO DE SOFTWARE

Yerson Stiven Cuellar Rubiano

Ficha de formación: 3145555

Expediente técnico y académico — APA 7

14 de octubre de 2026

Fuente documental: repositorios SaborExpressBack, SaborExpressWeb y SaborExpressMovil.

Las pruebas no ejecutadas se identifican como pendientes.

Catálogo de API y contratos de integración

Proyecto: SaborExpress | **Autor / integrante:** Yerson Stiven Cuellar Rubiano | **Ficha:** 3145555 | **Fecha:** 14 de octubre de 2026 | **Versión documental:** 4.0

Estado de la evidencia: inspección documental y estática del código. Las pruebas de ejecución y los datos institucionales no aportados no se presumen realizados.

1. Alcance y convenciones

Inventario verificado leyendo controladores seleccionados de la rama main de SaborExpressBack (corte: octubre de 2026). El resto de controladores existe, pero este catálogo no declara rutas no inspeccionadas. Prefijo /api, payload JSON salvo productos con FromForm; esquema JWT Bearer en Swagger.

Swagger: según SwaggerConfiguration.cs, interfaz en / y JSON en /swagger/v1/swagger.json si el backend está levantado; cambiar según reverse proxy. **SignalR:** /hubs/notifications en Program.cs. La respuesta y esquema completos se deben exportar del OpenAPI ejecutado.

2. Endpoints corroborados

Auth

Verbo	Ruta	Operación identificada
POST	/api/Auth/login	Autenticación
POST	/api/Auth/logout	Cerrar sesión
POST	/api/Auth/refresh-token	Renovar JWT
POST	/api/Auth/forgot-password	Solicitar recuperación
POST	/api/Auth/verify-reset-code	Verificar código
POST	/api/Auth/reset-password	Cambiar contraseña
POST	/api/Auth/confirm-email	Confirmar email
POST	/api/Auth/resend-confirmation-code	Reenviar confirmación
POST	/api/Auth/resend-activation-code	Reenviar activación
POST	/api/Auth/activate-account	Activar cuenta

Orders

Verbo	Ruta	Operación identificada
POST	/api/Orders	Crear pedido
GET	/api/Orders	Consultar pedidos
GET	/api/Orders/{id}	Detalle
GET	/api/Orders/table/{tableId}	Por mesa

Verbo	Ruta	Operación identificada
GET	/api/Orders/customer/{customerId}	Por cliente
GET	/api/Orders/branch/{branchId}	Por sede
PUT	/api/Orders/{id}	Actualizar
PATCH	/api/Orders/{id}/status	Actualizar estado
PATCH	/api/Orders/{id}/cancel-mine	Cancelar cliente
PATCH	/api/Orders/{id}/cancel	Cancelar operación

Products

Verbo	Ruta	Operación identificada
GET	/api/Products	Listar (público)
GET	/api/Products/category/{categoryId}	Por categoría (público)
GET	/api/Products/{id}	Detalle
POST	/api/Products	Crear
PUT	/api/Products/{id}	Actualizar
DELETE	/api/Products/{id}	Eliminar
PATCH	/api/Products/{id}/status	Estado

Payments

Verbo	Ruta	Operación identificada
POST	/api/Payments	Registrar pago
GET	/api/Payments	Listar con filtros
GET	/api/Payments/{id}	Detalle
GET	/api/Payments/order/{orderId}	Por pedido
GET	/api/Payments/my-shift	Cierre de turno
PATCH	/api/Payments/{id}/refund	Reembolso
POST	/api/Payments/wompi/init	Wompi iniciar cliente
POST	/api/Payments/wompi/cashier-init	Wompi QR cajero
POST	/api/Payments/{id}/wompi-sync	Sincronizar transacción
POST	/api/Payments/wompi/webhook	Webhook recibido

Deliveries

Verbo	Ruta	Operación identificada
POST	/api/Deliveries	Registrar entrega
GET	/api/Deliveries/order/{orderId}	Por pedido
GET	/api/Deliveries/employee/{deliveryPersonId}	Por repartidor
GET	/api/Deliveries/branch/{branchId}	Por sede
GET	/api/Deliveries/branch/{branchId}/delivery-persons	Repartidores disponibles
PATCH	/api/Deliveries/{id}/status	Estado de entrega
POST	/api/Deliveries/{id}/rating	Calificar

Branches

Verbo	Ruta	Operación identificada
GET	/api/Branches	Listar
GET	/api/Branches/mine	Mi sede
GET	/api/Branches/{id}	Detalle
POST	/api/Branches	Crear
PUT	/api/Branches/{id}	Actualizar

Verbo	Ruta	Operación identificada
DELETE	/api/Branches/{id}	Eliminar
GET	/api/Branches/public	Listado público según autorización de clase
GET	/api/Branches/nearest	Proximidad; revisar autorización de clase

3. Controles de autorización observados

OrdersController: clase marcada con [Authorize] y política [Authorize(Policy="ActiveShift")]; la cancelación del propio pedido requiere rol Cliente. ProductsController: GET del catálogo y por categoría permiten anónimo, mientras que escritura está restringida a Gerente/Administrador. PaymentsController: autenticación a nivel de clase; webhook con [AllowAnonymous]. DeliveriesController: incluye validaciones explícitas de sede/repartidor en algunas operaciones. BranchesController: está marcado [Authorize] a nivel de clase; sus métodos llamados public y nearest **no** llevan [AllowAnonymous] en el código inspeccionado. Debe revisarse porque un nombre de ruta no implica acceso público.

4. Ejemplos ilustrativos, NO contratos DTO exactos

Token: Authorization: Bearer <token_que_devuelva_login>. **Consulta de catálogo:** GET /api/Products?branchId=1. **Pedido:** la carga exacta depende de CreateOrderDto.cs; no se incluye un JSON inventado. **Webhook:** probar exclusivamente con eventos firmados del sandbox Wompi y de acuerdo con su documentación oficial.

5. Semántica de errores recomendada

200 lectura, 201 creación, 204 sin contenido, 400 solicitud inválida, 401 no autenticado, 403 sin permiso, 404 no encontrado, 409 conflicto, 422 reglas de negocio, 500 error inesperado. Se trata de guía según RFC 9110; las respuestas reales deben contrastarse con el filtro de excepciones del backend.

6. Compatibilidad/versionado

La implementación presenta rutas api/ sin prefijo de versión visible en los controladores inspeccionados. Antes del despliegue público, fijar contrato OpenAPI por commit, políticas de cambios incompatibles y colección Postman con variables de ambiente.

7. Guía de verificación

1. Ejecutar backend con BD de pruebas y configuración segura. 2. Solicitar GET /swagger/v1/swagger.json. 3. Importar especificación a Postman. 4. Verificar roles y sede en cada recurso. 5. Documentar ejemplos reales anonimizados. 6. Comparar rutas publicadas con este catálogo y corregir diferencias.

8. Fichas profesionales de contrato HTTP

Se amplían los endpoints inspeccionados. Para los atributos de autorización, esquemas DTO y respuestas, prevalece el controlador y DTO de la versión exacta: no se deben inferir parámetros no observados. Cada ficha propone casos de uso y pruebas, pero NO equivale a OpenAPI exportado de una instancia.

API-001. POST /api/Auth/login

Módulo: Auth. **Función declarada:** Autenticación. **Clase HTTP:** creación. **Autorización:** verificar atributo Authorize/roles y políticas del controlador.

Solicitud: los segmentos {id} y similares se sustituyen por identificadores sintéticos del entorno; query y JSON/form deben obtenerse de DTOs y atributos [FromQuery], [FromBody], [FromForm]. No asumir que todos los endpoints aceptan JSON.

Respuesta/errores a validar: consultar Swagger publicado en la misma versión; incluir caso normal, datos malformados, falta de token, rol no permitido, objeto ajeno y recurso inexistente. Para peticiones de escritura registrar antes/después en una base ficticia y confirmar que reintentar no duplica operaciones financieras.

Trazabilidad: integrar contrato en colección Postman y enlazar al test correspondiente; estado de pruebas de endpoint pendiente.

API-002. POST /api/Auth/logout

Módulo: Auth. **Función declarada:** Cerrar sesión. **Clase HTTP:** creación. **Autorización:** verificar atributo Authorize/roles y políticas del controlador.

Solicitud: los segmentos {id} y similares se sustituyen por identificadores sintéticos del entorno; query y JSON/form deben obtenerse de DTOs y atributos [FromQuery], [FromBody], [FromForm]. No asumir que todos los endpoints aceptan JSON.

Respuesta/errores a validar: consultar Swagger publicado en la misma versión; incluir caso normal, datos malformados, falta de token, rol no permitido, objeto ajeno y recurso inexistente. Para peticiones de escritura registrar antes/después en una base ficticia y confirmar que reintentar no duplica operaciones financieras.

Trazabilidad: integrar contrato en colección Postman y enlazar al test correspondiente; estado de pruebas de endpoint pendiente.

API-003. POST /api/Auth/refresh-token

Módulo: Auth. **Función declarada:** Renovar JWT. **Clase HTTP:** creación. **Autorización:** verificar atributo Authorize/roles y políticas del controlador.

Solicitud: los segmentos {id} y similares se sustituyen por identificadores sintéticos del entorno; query y JSON/form deben obtenerse de DTOs y atributos [FromQuery], [FromBody], [FromForm]. No asumir que todos los endpoints aceptan JSON.

Respuesta/errores a validar: consultar Swagger publicado en la misma versión; incluir caso normal, datos malformados, falta de token, rol no permitido, objeto ajeno y recurso inexistente. Para peticiones de escritura registrar antes/después en una base ficticia y confirmar que reintentar no duplica operaciones financieras.

Trazabilidad: integrar contrato en colección Postman y enlazar al test correspondiente; estado de pruebas de endpoint pendiente.

API-004. POST /api/Auth/forgot-password

Módulo: Auth. **Función declarada:** Solicitar recuperación. **Clase HTTP:** creación. **Autorización:** verificar atributo Authorize/roles y políticas del controlador.

Solicitud: los segmentos {id} y similares se sustituyen por identificadores sintéticos del entorno; query y JSON/form deben obtenerse de DTOs y atributos [FromQuery], [FromBody], [FromForm]. No asumir que todos los endpoints aceptan JSON.

Respuesta/errores a validar: consultar Swagger publicado en la misma versión; incluir caso normal, datos malformados, falta de token, rol no permitido, objeto ajeno y recurso inexistente. Para peticiones de escritura registrar antes/después en una base ficticia y confirmar que reintentar no duplica operaciones financieras.

Trazabilidad: integrar contrato en colección Postman y enlazar al test correspondiente; estado de pruebas de endpoint pendiente.

API-005. POST /api/Auth/verify-reset-code

Módulo: Auth. **Función declarada:** Verificar código. **Clase HTTP:** creación. **Autorización:** verificar atributo Authorize/roles y políticas del controlador.

Solicitud: los segmentos {id} y similares se sustituyen por identificadores sintéticos del entorno; query y JSON/form deben obtenerse de DTOs y atributos [FromQuery], [FromBody], [FromForm]. No asumir que todos los endpoints aceptan JSON.

Respuesta/errores a validar: consultar Swagger publicado en la misma versión; incluir caso normal, datos malformados, falta de token, rol no permitido, objeto ajeno y recurso inexistente. Para peticiones de escritura registrar antes/después en una base ficticia y confirmar que reintentar no duplica operaciones financieras.

Trazabilidad: integrar contrato en colección Postman y enlazar al test correspondiente; estado de pruebas de endpoint pendiente.

API-006. POST /api/Auth/reset-password

Módulo: Auth. **Función declarada:** Cambiar contraseña. **Clase HTTP:** creación. **Autorización:** verificar atributo Authorize/roles y políticas del controlador.

Solicitud: los segmentos {id} y similares se sustituyen por identificadores sintéticos del entorno; query y JSON/form deben obtenerse de DTOs y atributos [FromQuery], [FromBody], [FromForm]. No asumir que todos los endpoints aceptan JSON.

Respuesta/errores a validar: consultar Swagger publicado en la misma versión; incluir caso normal, datos malformados, falta de token, rol no permitido, objeto ajeno y recurso inexistente. Para peticiones de escritura registrar antes/después en una base ficticia y confirmar que reintentar no duplica operaciones financieras.

Trazabilidad: integrar contrato en colección Postman y enlazar al test correspondiente; estado de pruebas de endpoint pendiente.

API-007. POST /api/Auth/confirm-email

Módulo: Auth. **Función declarada:** Confirmar email. **Clase HTTP:** creación. **Autorización:** verificar atributo Authorize/roles y políticas del controlador.

Solicitud: los segmentos {id} y similares se sustituyen por identificadores sintéticos del entorno; query y JSON/form deben obtenerse de DTOs y atributos [FromQuery], [FromBody], [FromForm]. No asumir que todos los endpoints aceptan JSON.

Respuesta/errores a validar: consultar Swagger publicado en la misma versión; incluir caso normal, datos malformados, falta de token, rol no permitido, objeto ajeno y recurso inexistente. Para peticiones de escritura registrar antes/después en una base ficticia y confirmar que reintentar no duplica operaciones financieras.

Trazabilidad: integrar contrato en colección Postman y enlazar al test correspondiente; estado de pruebas de endpoint pendiente.

API-008. POST /api/Auth/resend-confirmation-code

Módulo: Auth. **Función declarada:** Reenviar confirmación. **Clase HTTP:** creación. **Autorización:** verificar atributo Authorize/roles y políticas del controlador.

Solicitud: los segmentos {id} y similares se sustituyen por identificadores sintéticos del entorno; query y JSON/form deben obtenerse de DTOs y atributos [FromQuery], [FromBody], [FromForm]. No asumir que todos los endpoints aceptan JSON.

Respuesta/errores a validar: consultar Swagger publicado en la misma versión; incluir caso normal, datos malformados, falta de token, rol no permitido, objeto ajeno y recurso inexistente. Para peticiones de escritura registrar antes/después en una base ficticia y confirmar que reintentar no duplica operaciones financieras.

Trazabilidad: integrar contrato en colección Postman y enlazar al test correspondiente; estado de pruebas de endpoint pendiente.

API-009. POST /api/Auth/resend-activation-code

Módulo: Auth. **Función declarada:** Reenviar activación. **Clase HTTP:** creación. **Autorización:** verificar atributo Authorize/roles y políticas del controlador.

Solicitud: los segmentos {id} y similares se sustituyen por identificadores sintéticos del entorno; query y JSON/form deben obtenerse de DTOs y atributos [FromQuery], [FromBody], [FromForm]. No asumir que todos los endpoints aceptan JSON.

Respuesta/errores a validar: consultar Swagger publicado en la misma versión; incluir caso normal, datos malformados, falta de token, rol no permitido, objeto ajeno y recurso inexistente. Para peticiones de escritura registrar antes/después en una base ficticia y confirmar que reintentar no duplica operaciones financieras.

Trazabilidad: integrar contrato en colección Postman y enlazar al test correspondiente; estado de pruebas de endpoint pendiente.

API-010. POST /api/Auth/activate-account

Módulo: Auth. **Función declarada:** Activar cuenta. **Clase HTTP:** creación. **Autorización:** verificar atributo Authorize/roles y políticas del controlador.

Solicitud: los segmentos {id} y similares se sustituyen por identificadores sintéticos del entorno; query y JSON/form deben obtenerse de DTOs y atributos [FromQuery], [FromBody], [FromForm]. No asumir que todos los endpoints aceptan JSON.

Respuesta/errores a validar: consultar Swagger publicado en la misma versión; incluir caso normal, datos malformados, falta de token, rol no permitido, objeto ajeno y recurso inexistente. Para peticiones de escritura registrar antes/después en una base ficticia y confirmar que reintentar no duplica operaciones financieras.

Trazabilidad: integrar contrato en colección Postman y enlazar al test correspondiente; estado de pruebas de endpoint pendiente.

API-011. POST /api/Orders

Módulo: Orders. **Función declarada:** Crear pedido. **Clase HTTP:** creación. **Autorización:** verificar atributo Authorize/roles y políticas del controlador.

Solicitud: los segmentos {id} y similares se sustituyen por identificadores sintéticos del entorno; query y JSON/form deben obtenerse de DTOs y atributos [FromQuery], [FromBody], [FromForm]. No asumir que todos los endpoints aceptan JSON.

Respuesta/errores a validar: consultar Swagger publicado en la misma versión; incluir caso normal, datos malformados, falta de token, rol no permitido, objeto ajeno y recurso inexistente. Para peticiones de escritura registrar antes/después en una base ficticia y confirmar que reintentar no duplica operaciones financieras.

Trazabilidad: integrar contrato en colección Postman y enlazar al test correspondiente; estado de pruebas de endpoint pendiente.

API-012. GET /api/Orders

Módulo: Orders. **Función declarada:** Consultar pedidos. **Clase HTTP:** consulta. **Autorización:** verificar atributo Authorize/roles y políticas del controlador.

Solicitud: los segmentos {id} y similares se sustituyen por identificadores sintéticos del entorno; query y JSON/form deben obtenerse de DTOs y atributos [FromQuery], [FromBody], [FromForm]. No asumir que todos los endpoints aceptan JSON.

Respuesta/errores a validar: consultar Swagger publicado en la misma versión; incluir caso normal, datos malformados, falta de token, rol no permitido, objeto ajeno y recurso inexistente. Para peticiones de escritura registrar antes/después en una base ficticia y confirmar que reintentar no duplica operaciones financieras.

Trazabilidad: integrar contrato en colección Postman y enlazar al test correspondiente; estado de pruebas de endpoint pendiente.

API-013. GET /api/Orders/{id}

Módulo: Orders. **Función declarada:** Detalle. **Clase HTTP:** consulta. **Autorización:** verificar atributo Authorize/roles y políticas del controlador.

Solicitud: los segmentos {id} y similares se sustituyen por identificadores sintéticos del entorno; query y JSON/form deben obtenerse de DTOs y atributos [FromQuery], [FromBody], [FromForm]. No asumir que todos los endpoints aceptan JSON.

Respuesta/errores a validar: consultar Swagger publicado en la misma versión; incluir caso normal, datos malformados, falta de token, rol no permitido, objeto ajeno y recurso inexistente. Para peticiones de escritura registrar antes/después en una base ficticia y confirmar que reintentar no duplica operaciones financieras.

Trazabilidad: integrar contrato en colección Postman y enlazar al test correspondiente; estado de pruebas de endpoint pendiente.

API-014. GET /api/Orders/table/{tableId}

Módulo: Orders. **Función declarada:** Por mesa. **Clase HTTP:** consulta. **Autorización:** verificar atributo Authorize/roles y políticas del controlador.

Solicitud: los segmentos {id} y similares se sustituyen por identificadores sintéticos del entorno; query y JSON/form deben obtenerse de DTOs y atributos [FromQuery], [FromBody], [FromForm]. No asumir que todos los endpoints aceptan JSON.

Respuesta/errores a validar: consultar Swagger publicado en la misma versión; incluir caso normal, datos malformados, falta de token, rol no permitido, objeto ajeno y recurso inexistente. Para peticiones de escritura registrar antes/después en una base ficticia y confirmar que reintentar no duplica operaciones financieras.

Trazabilidad: integrar contrato en colección Postman y enlazar al test correspondiente; estado de pruebas de endpoint pendiente.

API-015. GET /api/Orders/customer/{customerId}

Módulo: Orders. **Función declarada:** Por cliente. **Clase HTTP:** consulta. **Autorización:** verificar atributo Authorize/roles y políticas del controlador.

Solicitud: los segmentos {id} y similares se sustituyen por identificadores sintéticos del entorno; query y JSON/form deben obtenerse de DTOs y atributos [FromQuery], [FromBody], [FromForm]. No asumir que todos los endpoints aceptan JSON.

Respuesta/errores a validar: consultar Swagger publicado en la misma versión; incluir caso normal, datos malformados, falta de token, rol no permitido, objeto ajeno y recurso inexistente. Para peticiones de escritura registrar antes/después en una base ficticia y confirmar que reintentar no duplica operaciones financieras.

Trazabilidad: integrar contrato en colección Postman y enlazar al test correspondiente; estado de pruebas de endpoint pendiente.

API-016. GET /api/Orders/branch/{branchId}

Módulo: Orders. **Función declarada:** Por sede. **Clase HTTP:** consulta. **Autorización:** verificar atributo Authorize/roles y políticas del controlador.

Solicitud: los segmentos {id} y similares se sustituyen por identificadores sintéticos del entorno; query y JSON/form deben obtenerse de DTOs y atributos [FromQuery], [FromBody], [FromForm]. No asumir que todos los endpoints aceptan JSON.

Respuesta/errores a validar: consultar Swagger publicado en la misma versión; incluir caso normal, datos malformados, falta de token, rol no permitido, objeto ajeno y recurso inexistente. Para peticiones de escritura registrar antes/después en una base ficticia y confirmar que reintentar no duplica operaciones financieras.

Trazabilidad: integrar contrato en colección Postman y enlazar al test correspondiente; estado de pruebas de endpoint pendiente.

API-017. PUT /api/Orders/{id}

Módulo: Orders. **Función declarada:** Actualizar. **Clase HTTP:** modificación. **Autorización:** verificar atributo Authorize/roles y políticas del controlador.

Solicitud: los segmentos {id} y similares se sustituyen por identificadores sintéticos del entorno; query y JSON/form deben obtenerse de DTOs y atributos [FromQuery], [FromBody], [FromForm]. No asumir que todos los endpoints aceptan JSON.

Respuesta/errores a validar: consultar Swagger publicado en la misma versión; incluir caso normal, datos malformados, falta de token, rol no permitido, objeto ajeno y recurso inexistente. Para peticiones de escritura registrar antes/después en una base ficticia y confirmar que reintentar no duplica operaciones financieras.

Trazabilidad: integrar contrato en colección Postman y enlazar al test correspondiente; estado de pruebas de endpoint pendiente.

API-018. PATCH /api/Orders/{id}/status

Módulo: Orders. **Función declarada:** Actualizar estado. **Clase HTTP:** modificación. **Autorización:** verificar atributo Authorize/roles y políticas del controlador.

Solicitud: los segmentos {id} y similares se sustituyen por identificadores sintéticos del entorno; query y JSON/form deben obtenerse de DTOs y atributos [FromQuery], [FromBody], [FromForm]. No asumir que todos los endpoints aceptan JSON.

Respuesta/errores a validar: consultar Swagger publicado en la misma versión; incluir caso normal, datos malformados, falta de token, rol no permitido, objeto ajeno y recurso inexistente. Para peticiones de escritura registrar antes/después en una base ficticia y confirmar que reintentar no duplica operaciones financieras.

Trazabilidad: integrar contrato en colección Postman y enlazar al test correspondiente; estado de pruebas de endpoint pendiente.

API-019. PATCH /api/Orders/{id}/cancel-mine

Módulo: Orders. **Función declarada:** Cancelar cliente. **Clase HTTP:** modificación. **Autorización:** verificar atributo Authorize/roles y políticas del controlador.

Solicitud: los segmentos {id} y similares se sustituyen por identificadores sintéticos del entorno; query y JSON/form deben obtenerse de DTOs y atributos [FromQuery], [FromBody], [FromForm]. No asumir que todos los endpoints aceptan JSON.

Respuesta/errores a validar: consultar Swagger publicado en la misma versión; incluir caso normal, datos malformados, falta de token, rol no permitido, objeto ajeno y recurso inexistente. Para peticiones de escritura registrar antes/después en una base ficticia y confirmar que reintentar no duplica operaciones financieras.

Trazabilidad: integrar contrato en colección Postman y enlazar al test correspondiente; estado de pruebas de endpoint pendiente.

API-020. PATCH /api/Orders/{id}/cancel

Módulo: Orders. **Función declarada:** Cancelar operación. **Clase HTTP:** modificación. **Autorización:** verificar atributo Authorize/roles y políticas del controlador.

Solicitud: los segmentos {id} y similares se sustituyen por identificadores sintéticos del entorno; query y JSON/form deben obtenerse de DTOs y atributos [FromQuery], [FromBody], [FromForm]. No asumir que todos los endpoints aceptan JSON.

Respuesta/errores a validar: consultar Swagger publicado en la misma versión; incluir caso normal, datos malformados, falta de token, rol no permitido, objeto ajeno y recurso inexistente. Para peticiones de escritura registrar antes/después en una base ficticia y confirmar que reintentar no duplica operaciones financieras.

Trazabilidad: integrar contrato en colección Postman y enlazar al test correspondiente; estado de pruebas de endpoint pendiente.

API-021. GET /api/Products

Módulo: Products. **Función declarada:** Listar (público). **Clase HTTP:** consulta. **Autorización:** público según atributos inspeccionados.

Solicitud: los segmentos {id} y similares se sustituyen por identificadores sintéticos del entorno; query y JSON/form deben obtenerse de DTOs y atributos [FromQuery], [FromBody], [FromForm]. No asumir que todos los endpoints aceptan JSON.

Respuesta/errores a validar: consultar Swagger publicado en la misma versión; incluir caso normal, datos malformados, falta de token, rol no permitido, objeto ajeno y recurso inexistente. Para peticiones de escritura registrar antes/después en una base ficticia y confirmar que reintentar no duplica operaciones financieras.

Trazabilidad: integrar contrato en colección Postman y enlazar al test correspondiente; estado de pruebas de endpoint pendiente.

API-022. GET /api/Products/category/{categoryId}

Módulo: Products. **Función declarada:** Por categoría (público). **Clase HTTP:** consulta. **Autorización:** público según atributos inspeccionados.

Solicitud: los segmentos {id} y similares se sustituyen por identificadores sintéticos del entorno; query y JSON/form deben obtenerse de DTOs y atributos [FromQuery], [FromBody], [FromForm]. No asumir que todos los endpoints aceptan JSON.

Respuesta/errores a validar: consultar Swagger publicado en la misma versión; incluir caso normal, datos malformados, falta de token, rol no permitido, objeto ajeno y recurso inexistente. Para peticiones de escritura registrar antes/después en una base ficticia y confirmar que reintentar no duplica operaciones financieras.

Trazabilidad: integrar contrato en colección Postman y enlazar al test correspondiente; estado de pruebas de endpoint pendiente.

API-023. GET /api/Products/{id}

Módulo: Products. **Función declarada:** Detalle. **Clase HTTP:** consulta. **Autorización:** verificar atributo Authorize/roles y políticas del controlador.

Solicitud: los segmentos {id} y similares se sustituyen por identificadores sintéticos del entorno; query y JSON/form deben obtenerse de DTOs y atributos [FromQuery], [FromBody], [FromForm]. No asumir que todos los endpoints aceptan JSON.

Respuesta/errores a validar: consultar Swagger publicado en la misma versión; incluir caso normal, datos malformados, falta de token, rol no permitido, objeto ajeno y recurso inexistente. Para peticiones de escritura registrar antes/después en una base ficticia y confirmar que reintentar no duplica operaciones financieras.

Trazabilidad: integrar contrato en colección Postman y enlazar al test correspondiente; estado de pruebas de endpoint pendiente.

API-024. POST /api/Products

Módulo: Products. **Función declarada:** Crear. **Clase HTTP:** creación. **Autorización:** público según atributos inspeccionados.

Solicitud: los segmentos {id} y similares se sustituyen por identificadores sintéticos del entorno; query y JSON/form deben obtenerse de DTOs y atributos [FromQuery], [FromBody], [FromForm]. No asumir que todos los endpoints aceptan JSON.

Respuesta/errores a validar: consultar Swagger publicado en la misma versión; incluir caso normal, datos malformados, falta de token, rol no permitido, objeto ajeno y recurso inexistente. Para peticiones de escritura registrar antes/después en una base ficticia y confirmar que reintentar no duplica operaciones financieras.

Trazabilidad: integrar contrato en colección Postman y enlazar al test correspondiente; estado de pruebas de endpoint pendiente.

API-025. PUT /api/Products/{id}

Módulo: Products. **Función declarada:** Actualizar. **Clase HTTP:** modificación. **Autorización:** verificar atributo Authorize/roles y políticas del controlador.

Solicitud: los segmentos {id} y similares se sustituyen por identificadores sintéticos del entorno; query y JSON/form deben obtenerse de DTOs y atributos [FromQuery], [FromBody], [FromForm]. No asumir que todos los endpoints aceptan JSON.

Respuesta/errores a validar: consultar Swagger publicado en la misma versión; incluir caso normal, datos malformados, falta de token, rol no permitido, objeto ajeno y recurso inexistente. Para peticiones de escritura registrar antes/después en una base ficticia y confirmar que reintentar no duplica operaciones financieras.

Trazabilidad: integrar contrato en colección Postman y enlazar al test correspondiente; estado de pruebas de endpoint pendiente.

API-026. DELETE /api/Products/{id}

Módulo: Products. **Función declarada:** Eliminar. **Clase HTTP:** eliminación. **Autorización:** verificar atributo Authorize/roles y políticas del controlador.

Solicitud: los segmentos {id} y similares se sustituyen por identificadores sintéticos del entorno; query y JSON/form deben obtenerse de DTOs y atributos [FromQuery], [FromBody], [FromForm]. No asumir que todos los endpoints aceptan JSON.

Respuesta/errores a validar: consultar Swagger publicado en la misma versión; incluir caso normal, datos malformados, falta de token, rol no permitido, objeto ajeno y recurso inexistente. Para peticiones de escritura registrar antes/después en una base ficticia y confirmar que reintentar no duplica operaciones financieras.

Trazabilidad: integrar contrato en colección Postman y enlazar al test correspondiente; estado de pruebas de endpoint pendiente.

API-027. PATCH /api/Products/{id}/status

Módulo: Products. **Función declarada:** Estado. **Clase HTTP:** modificación. **Autorización:** verificar atributo Authorize/roles y políticas del controlador.

Solicitud: los segmentos {id} y similares se sustituyen por identificadores sintéticos del entorno; query y JSON/form deben obtenerse de DTOs y atributos [FromQuery], [FromBody], [FromForm]. No asumir que todos los endpoints aceptan JSON.

Respuesta/errores a validar: consultar Swagger publicado en la misma versión; incluir caso normal, datos malformados, falta de token, rol no permitido, objeto ajeno y recurso inexistente. Para peticiones de escritura registrar antes/después en una base ficticia y confirmar que reintentar no duplica operaciones financieras.

Trazabilidad: integrar contrato en colección Postman y enlazar al test correspondiente; estado de pruebas de endpoint pendiente.

API-028. POST /api/Payments

Módulo: Payments. **Función declarada:** Registrar pago. **Clase HTTP:** creación. **Autorización:** verificar atributo Authorize/roles y políticas del controlador.

Solicitud: los segmentos {id} y similares se sustituyen por identificadores sintéticos del entorno; query y JSON/form deben obtenerse de DTOs y atributos [FromQuery], [FromBody], [FromForm]. No asumir que todos los endpoints aceptan JSON.

Respuesta/errores a validar: consultar Swagger publicado en la misma versión; incluir caso normal, datos malformados, falta de token, rol no permitido, objeto ajeno y recurso inexistente. Para peticiones de escritura registrar antes/después en una base ficticia y confirmar que reintentar no duplica operaciones financieras.

Trazabilidad: integrar contrato en colección Postman y enlazar al test correspondiente; estado de pruebas de endpoint pendiente.

API-029. GET /api/Payments

Módulo: Payments. **Función declarada:** Listar con filtros. **Clase HTTP:** consulta. **Autorización:** verificar atributo Authorize/roles y políticas del controlador.

Solicitud: los segmentos {id} y similares se sustituyen por identificadores sintéticos del entorno; query y JSON/form deben obtenerse de DTOs y atributos [FromQuery], [FromBody], [FromForm]. No asumir que todos los endpoints aceptan JSON.

Respuesta/errores a validar: consultar Swagger publicado en la misma versión; incluir caso normal, datos malformados, falta de token, rol no permitido, objeto ajeno y recurso inexistente. Para peticiones de escritura registrar antes/después en una base ficticia y confirmar que reintentar no duplica operaciones financieras.

Trazabilidad: integrar contrato en colección Postman y enlazar al test correspondiente; estado de pruebas de endpoint pendiente.

API-030. GET /api/Payments/{id}

Módulo: Payments. **Función declarada:** Detalle. **Clase HTTP:** consulta. **Autorización:** verificar atributo Authorize/roles y políticas del controlador.

Solicitud: los segmentos {id} y similares se sustituyen por identificadores sintéticos del entorno; query y JSON/form deben obtenerse de DTOs y atributos [FromQuery], [FromBody], [FromForm]. No asumir que todos los endpoints aceptan JSON.

Respuesta/errores a validar: consultar Swagger publicado en la misma versión; incluir caso normal, datos malformados, falta de token, rol no permitido, objeto ajeno y recurso inexistente. Para peticiones de escritura registrar antes/después en una base ficticia y confirmar que reintentar no duplica operaciones financieras.

Trazabilidad: integrar contrato en colección Postman y enlazar al test correspondiente; estado de pruebas de endpoint pendiente.

API-031. GET /api/Payments/order/{orderId}

Módulo: Payments. **Función declarada:** Por pedido. **Clase HTTP:** consulta. **Autorización:** verificar atributo Authorize/roles y políticas del controlador.

Solicitud: los segmentos {id} y similares se sustituyen por identificadores sintéticos del entorno; query y JSON/form deben obtenerse de DTOs y atributos [FromQuery], [FromBody], [FromForm]. No asumir que todos los endpoints aceptan JSON.

Respuesta/errores a validar: consultar Swagger publicado en la misma versión; incluir caso normal, datos malformados, falta de token, rol no permitido, objeto ajeno y recurso inexistente. Para peticiones de escritura registrar antes/después en una base ficticia y confirmar que reintentar no duplica operaciones financieras.

Trazabilidad: integrar contrato en colección Postman y enlazar al test correspondiente; estado de pruebas de endpoint pendiente.

API-032. GET /api/Payments/my-shift

Módulo: Payments. **Función declarada:** Cierre de turno. **Clase HTTP:** consulta.
Autorización: verificar atributo Authorize/roles y políticas del controlador.

Solicitud: los segmentos {id} y similares se sustituyen por identificadores sintéticos del entorno; query y JSON/form deben obtenerse de DTOs y atributos [FromQuery], [FromBody], [FromForm]. No asumir que todos los endpoints aceptan JSON.

Respuesta/errores a validar: consultar Swagger publicado en la misma versión; incluir caso normal, datos malformados, falta de token, rol no permitido, objeto ajeno y recurso inexistente. Para peticiones de escritura registrar antes/después en una base ficticia y confirmar que reintentar no duplica operaciones financieras.

Trazabilidad: integrar contrato en colección Postman y enlazar al test correspondiente; estado de pruebas de endpoint pendiente.

API-033. PATCH /api/Payments/{id}/refund

Módulo: Payments. **Función declarada:** Reembolso. **Clase HTTP:** modificación.
Autorización: verificar atributo Authorize/roles y políticas del controlador.

Solicitud: los segmentos {id} y similares se sustituyen por identificadores sintéticos del entorno; query y JSON/form deben obtenerse de DTOs y atributos [FromQuery], [FromBody], [FromForm]. No asumir que todos los endpoints aceptan JSON.

Respuesta/errores a validar: consultar Swagger publicado en la misma versión; incluir caso normal, datos malformados, falta de token, rol no permitido, objeto ajeno y recurso inexistente. Para peticiones de escritura registrar antes/después en una base ficticia y confirmar que reintentar no duplica operaciones financieras.

Trazabilidad: integrar contrato en colección Postman y enlazar al test correspondiente; estado de pruebas de endpoint pendiente.

API-034. POST /api/Payments/wompi/init

Módulo: Payments. **Función declarada:** Wompi iniciar cliente. **Clase HTTP:** creación. **Autorización:** verificar atributo Authorize/roles y políticas del controlador.

Solicitud: los segmentos {id} y similares se sustituyen por identificadores sintéticos del entorno; query y JSON/form deben obtenerse de DTOs y atributos [FromQuery], [FromBody], [FromForm]. No asumir que todos los endpoints aceptan JSON.

Respuesta/errores a validar: consultar Swagger publicado en la misma versión; incluir caso normal, datos malformados, falta de token, rol no permitido, objeto ajeno y recurso inexistente. Para peticiones de escritura registrar antes/después en una base ficticia y confirmar que reintentar no duplica operaciones financieras.

Trazabilidad: integrar contrato en colección Postman y enlazar al test correspondiente; estado de pruebas de endpoint pendiente.

API-035. POST /api/Payments/wompi/cashier-init

Módulo: Payments. **Función declarada:** Wompi QR cajero. **Clase HTTP:** creación. **Autorización:** verificar atributo Authorize/roles y políticas del controlador.

Solicitud: los segmentos {id} y similares se sustituyen por identificadores sintéticos del entorno; query y JSON/form deben obtenerse de DTOs y atributos [FromQuery], [FromBody], [FromForm]. No asumir que todos los endpoints aceptan JSON.

Respuesta/errores a validar: consultar Swagger publicado en la misma versión; incluir caso normal, datos malformados, falta de token, rol no permitido, objeto ajeno y recurso inexistente. Para peticiones de escritura registrar antes/después en una base ficticia y confirmar que reintentar no duplica operaciones financieras.

Trazabilidad: integrar contrato en colección Postman y enlazar al test correspondiente; estado de pruebas de endpoint pendiente.

API-036. POST /api/Payments/{id}/wompi-sync

Módulo: Payments. **Función declarada:** Sincronizar transacción. **Clase HTTP:** creación. **Autorización:** verificar atributo Authorize/roles y políticas del controlador.

Solicitud: los segmentos {id} y similares se sustituyen por identificadores sintéticos del entorno; query y JSON/form deben obtenerse de DTOs y atributos [FromQuery], [FromBody], [FromForm]. No asumir que todos los endpoints aceptan JSON.

Respuesta/errores a validar: consultar Swagger publicado en la misma versión; incluir caso normal, datos malformados, falta de token, rol no permitido, objeto ajeno y recurso inexistente. Para peticiones de escritura registrar antes/después en una base ficticia y confirmar que reintentar no duplica operaciones financieras.

Trazabilidad: integrar contrato en colección Postman y enlazar al test correspondiente; estado de pruebas de endpoint pendiente.

API-037. POST /api/Payments/wompi/webhook

Módulo: Payments. **Función declarada:** Webhook recibido. **Clase HTTP:** creación. **Autorización:** público según atributos inspeccionados.

Solicitud: los segmentos {id} y similares se sustituyen por identificadores sintéticos del entorno; query y JSON/form deben obtenerse de DTOs y atributos [FromQuery], [FromBody], [FromForm]. No asumir que todos los endpoints aceptan JSON.

Respuesta/errores a validar: consultar Swagger publicado en la misma versión; incluir caso normal, datos malformados, falta de token, rol no permitido, objeto ajeno y recurso inexistente. Para peticiones de escritura registrar antes/después en una base ficticia y confirmar que reintentar no duplica operaciones financieras.

Trazabilidad: integrar contrato en colección Postman y enlazar al test correspondiente; estado de pruebas de endpoint pendiente.

API-038. POST /api/Deliveries

Módulo: Deliveries. **Función declarada:** Registrar entrega. **Clase HTTP:** creación. **Autorización:** verificar atributo Authorize/roles y políticas del controlador.

Solicitud: los segmentos {id} y similares se sustituyen por identificadores sintéticos del entorno; query y JSON/form deben obtenerse de DTOs y atributos [FromQuery], [FromBody], [FromForm]. No asumir que todos los endpoints aceptan JSON.

Respuesta/errores a validar: consultar Swagger publicado en la misma versión; incluir caso normal, datos malformados, falta de token, rol no permitido, objeto ajeno y recurso inexistente. Para peticiones de escritura registrar antes/después en una base ficticia y confirmar que reintentar no duplica operaciones financieras.

Trazabilidad: integrar contrato en colección Postman y enlazar al test correspondiente; estado de pruebas de endpoint pendiente.

API-039. GET /api/Deliveries/order/{orderId}

Módulo: Deliveries. **Función declarada:** Por pedido. **Clase HTTP:** consulta. **Autorización:** verificar atributo Authorize/roles y políticas del controlador.

Solicitud: los segmentos {id} y similares se sustituyen por identificadores sintéticos del entorno; query y JSON/form deben obtenerse de DTOs y atributos [FromQuery], [FromBody], [FromForm]. No asumir que todos los endpoints aceptan JSON.

Respuesta/errores a validar: consultar Swagger publicado en la misma versión; incluir caso normal, datos malformados, falta de token, rol no permitido, objeto ajeno y recurso inexistente. Para peticiones de escritura registrar antes/después en una base ficticia y confirmar que reintentar no duplica operaciones financieras.

Trazabilidad: integrar contrato en colección Postman y enlazar al test correspondiente; estado de pruebas de endpoint pendiente.

API-040. GET /api/Deliveries/employee/{deliveryPersonId}

Módulo: Deliveries. **Función declarada:** Por repartidor. **Clase HTTP:** consulta. **Autorización:** verificar atributo Authorize/roles y políticas del controlador.

Solicitud: los segmentos {id} y similares se sustituyen por identificadores sintéticos del entorno; query y JSON/form deben obtenerse de DTOs y atributos [FromQuery], [FromBody], [FromForm]. No asumir que todos los endpoints aceptan JSON.

Respuesta/errores a validar: consultar Swagger publicado en la misma versión; incluir caso normal, datos malformados, falta de token, rol no permitido, objeto ajeno y recurso inexistente. Para peticiones de escritura registrar antes/después en una base ficticia y confirmar que reintentar no duplica operaciones financieras.

Trazabilidad: integrar contrato en colección Postman y enlazar al test correspondiente; estado de pruebas de endpoint pendiente.

API-041. GET /api/Deliveries/branch/{branchId}

Módulo: Deliveries. **Función declarada:** Por sede. **Clase HTTP:** consulta. **Autorización:** verificar atributo Authorize/roles y políticas del controlador.

Solicitud: los segmentos {id} y similares se sustituyen por identificadores sintéticos del entorno; query y JSON/form deben obtenerse de DTOs y atributos [FromQuery], [FromBody], [FromForm]. No asumir que todos los endpoints aceptan JSON.

Respuesta/errores a validar: consultar Swagger publicado en la misma versión; incluir caso normal, datos malformados, falta de token, rol no permitido, objeto ajeno y recurso inexistente. Para peticiones de escritura registrar antes/después en una base ficticia y confirmar que reintentar no duplica operaciones financieras.

Trazabilidad: integrar contrato en colección Postman y enlazar al test correspondiente; estado de pruebas de endpoint pendiente.

API-042. GET /api/Deliveries/branch/{branchId}/delivery-persons

Módulo: Deliveries. **Función declarada:** Repartidores disponibles. **Clase HTTP:** consulta. **Autorización:** verificar atributo Authorize/roles y políticas del controlador.

Solicitud: los segmentos {id} y similares se sustituyen por identificadores sintéticos del entorno; query y JSON/form deben obtenerse de DTOs y atributos [FromQuery], [FromBody], [FromForm]. No asumir que todos los endpoints aceptan JSON.

Respuesta/errores a validar: consultar Swagger publicado en la misma versión; incluir caso normal, datos malformados, falta de token, rol no permitido, objeto ajeno y recurso inexistente. Para peticiones de escritura registrar antes/después en una base ficticia y confirmar que reintentar no duplica operaciones financieras.

Trazabilidad: integrar contrato en colección Postman y enlazar al test correspondiente; estado de pruebas de endpoint pendiente.

API-043. PATCH /api/Deliveries/{id}/status

Módulo: Deliveries. **Función declarada:** Estado de entrega. **Clase HTTP:** modificación. **Autorización:** verificar atributo Authorize/roles y políticas del controlador.

Solicitud: los segmentos {id} y similares se sustituyen por identificadores sintéticos del entorno; query y JSON/form deben obtenerse de DTOs y atributos [FromQuery], [FromBody], [FromForm]. No asumir que todos los endpoints aceptan JSON.

Respuesta/errores a validar: consultar Swagger publicado en la misma versión; incluir caso normal, datos malformados, falta de token, rol no permitido, objeto ajeno y recurso inexistente. Para peticiones de escritura registrar antes/después en una base ficticia y confirmar que reintentar no duplica operaciones financieras.

Trazabilidad: integrar contrato en colección Postman y enlazar al test correspondiente; estado de pruebas de endpoint pendiente.

API-044. POST /api/Deliveries/{id}/rating

Módulo: Deliveries. **Función declarada:** Calificar. **Clase HTTP:** creación. **Autorización:** verificar atributo Authorize/roles y políticas del controlador.

Solicitud: los segmentos {id} y similares se sustituyen por identificadores sintéticos del entorno; query y JSON/form deben obtenerse de DTOs y atributos [FromQuery], [FromBody], [FromForm]. No asumir que todos los endpoints aceptan JSON.

Respuesta/errores a validar: consultar Swagger publicado en la misma versión; incluir caso normal, datos malformados, falta de token, rol no permitido, objeto ajeno y recurso inexistente. Para peticiones de escritura registrar antes/después en una base ficticia y confirmar que reintentar no duplica operaciones financieras.

Trazabilidad: integrar contrato en colección Postman y enlazar al test correspondiente; estado de pruebas de endpoint pendiente.

API-045. GET /api/Branches

Módulo: Branches. **Función declarada:** Listar. **Clase HTTP:** consulta. **Autorización:** verificar atributo Authorize/roles y políticas del controlador.

Solicitud: los segmentos {id} y similares se sustituyen por identificadores sintéticos del entorno; query y JSON/form deben obtenerse de DTOs y atributos [FromQuery], [FromBody], [FromForm]. No asumir que todos los endpoints aceptan JSON.

Respuesta/errores a validar: consultar Swagger publicado en la misma versión; incluir caso normal, datos malformados, falta de token, rol no permitido, objeto ajeno y recurso inexistente. Para peticiones de escritura registrar antes/después en una base ficticia y confirmar que reintentar no duplica operaciones financieras.

Trazabilidad: integrar contrato en colección Postman y enlazar al test correspondiente; estado de pruebas de endpoint pendiente.

API-046. GET /api/Branches/mine

Módulo: Branches. **Función declarada:** Mi sede. **Clase HTTP:** consulta. **Autorización:** verificar atributo Authorize/roles y políticas del controlador.

Solicitud: los segmentos {id} y similares se sustituyen por identificadores sintéticos del entorno; query y JSON/form deben obtenerse de DTOs y atributos [FromQuery], [FromBody], [FromForm]. No asumir que todos los endpoints aceptan JSON.

Respuesta/errores a validar: consultar Swagger publicado en la misma versión; incluir caso normal, datos malformados, falta de token, rol no permitido, objeto ajeno y recurso inexistente. Para peticiones de escritura registrar antes/después en una base ficticia y confirmar que reintentar no duplica operaciones financieras.

Trazabilidad: integrar contrato en colección Postman y enlazar al test correspondiente; estado de pruebas de endpoint pendiente.

API-047. GET /api/Branches/{id}

Módulo: Branches. **Función declarada:** Detalle. **Clase HTTP:** consulta. **Autorización:** verificar atributo Authorize/roles y políticas del controlador.

Solicitud: los segmentos {id} y similares se sustituyen por identificadores sintéticos del entorno; query y JSON/form deben obtenerse de DTOs y atributos [FromQuery], [FromBody], [FromForm]. No asumir que todos los endpoints aceptan JSON.

Respuesta/errores a validar: consultar Swagger publicado en la misma versión; incluir caso normal, datos malformados, falta de token, rol no permitido, objeto ajeno y recurso inexistente. Para peticiones de escritura registrar antes/después en una base ficticia y confirmar que reintentar no duplica operaciones financieras.

Trazabilidad: integrar contrato en colección Postman y enlazar al test correspondiente; estado de pruebas de endpoint pendiente.

API-048. POST /api/Branches

Módulo: Branches. **Función declarada:** Crear. **Clase HTTP:** creación. **Autorización:** verificar atributo Authorize/roles y políticas del controlador.

Solicitud: los segmentos {id} y similares se sustituyen por identificadores sintéticos del entorno; query y JSON/form deben obtenerse de DTOs y atributos [FromQuery], [FromBody], [FromForm]. No asumir que todos los endpoints aceptan JSON.

Respuesta/errores a validar: consultar Swagger publicado en la misma versión; incluir caso normal, datos malformados, falta de token, rol no permitido, objeto ajeno y recurso inexistente. Para peticiones de escritura registrar antes/después en una base ficticia y confirmar que reintentar no duplica operaciones financieras.

Trazabilidad: integrar contrato en colección Postman y enlazar al test correspondiente; estado de pruebas de endpoint pendiente.

API-049. PUT /api/Branches/{id}

Módulo: Branches. **Función declarada:** Actualizar. **Clase HTTP:** modificación. **Autorización:** verificar atributo Authorize/roles y políticas del controlador.

Solicitud: los segmentos {id} y similares se sustituyen por identificadores sintéticos del entorno; query y JSON/form deben obtenerse de DTOs y atributos [FromQuery], [FromBody], [FromForm]. No asumir que todos los endpoints aceptan JSON.

Respuesta/errores a validar: consultar Swagger publicado en la misma versión; incluir caso normal, datos malformados, falta de token, rol no permitido, objeto ajeno y recurso inexistente. Para peticiones de escritura registrar antes/después en una base ficticia y confirmar que reintentar no duplica operaciones financieras.

Trazabilidad: integrar contrato en colección Postman y enlazar al test correspondiente; estado de pruebas de endpoint pendiente.

API-050. DELETE /api/Branches/{id}

Módulo: Branches. **Función declarada:** Eliminar. **Clase HTTP:** eliminación. **Autorización:** verificar atributo Authorize/roles y políticas del controlador.

Solicitud: los segmentos {id} y similares se sustituyen por identificadores sintéticos del entorno; query y JSON/form deben obtenerse de DTOs y atributos [FromQuery], [FromBody], [FromForm]. No asumir que todos los endpoints aceptan JSON.

Respuesta/errores a validar: consultar Swagger publicado en la misma versión; incluir caso normal, datos malformados, falta de token, rol no permitido, objeto ajeno y recurso inexistente. Para peticiones de escritura registrar antes/después en una base ficticia y confirmar que reintentar no duplica operaciones financieras.

Trazabilidad: integrar contrato en colección Postman y enlazar al test correspondiente; estado de pruebas de endpoint pendiente.

API-051. GET /api/Branches/public

Módulo: Branches. **Función declarada:** Listado público según autorización de clase. **Clase HTTP:** consulta. **Autorización:** verificar atributo Authorize/roles y políticas del controlador.

Solicitud: los segmentos {id} y similares se sustituyen por identificadores sintéticos del entorno; query y JSON/form deben obtenerse de DTOs y atributos [FromQuery], [FromBody], [FromForm]. No asumir que todos los endpoints aceptan JSON.

Respuesta/errores a validar: consultar Swagger publicado en la misma versión; incluir caso normal, datos malformados, falta de token, rol no permitido, objeto ajeno y recurso inexistente. Para peticiones de escritura registrar antes/después en una base ficticia y confirmar que reintentar no duplica operaciones financieras.

Trazabilidad: integrar contrato en colección Postman y enlazar al test correspondiente; estado de pruebas de endpoint pendiente.

API-052. GET /api/Branches/nearest

Módulo: Branches. **Función declarada:** Proximidad; revisar autorización de clase. **Clase HTTP:** consulta. **Autorización:** verificar atributo Authorize/roles y políticas del controlador.

Solicitud: los segmentos {id} y similares se sustituyen por identificadores sintéticos del entorno; query y JSON/form deben obtenerse de DTOs y atributos [FromQuery], [FromBody], [FromForm]. No asumir que todos los endpoints aceptan JSON.

Respuesta/errores a validar: consultar Swagger publicado en la misma versión; incluir caso normal, datos malformados, falta de token, rol no permitido, objeto ajeno y recurso inexistente. Para peticiones de escritura registrar antes/después en una base ficticia y confirmar que reintentar no duplica operaciones financieras.

Trazabilidad: integrar contrato en colección Postman y enlazar al test correspondiente; estado de pruebas de endpoint pendiente.

9. Ejemplos didácticos de petición y respuesta

Nota: ejemplos genéricos, no DTOs definitivos. Los campos exactos de LoginDto, CreateOrderDto y InitWompiPaymentDto deben obtenerse del código al versionar el OpenAPI.

```
POST /api/Auth/login HTTP/1.1
Host: api-desarrollo.example.test
Content-Type: application/json

{ "email": "usuario.pruebas@example.test", "password": "VALOR_PROTEGIDO" }
```

```
GET /api/Products?branchId=1 HTTP/1.1
Host: api-desarrollo.example.test
Accept: application/json

GET /api/Orders/1 HTTP/1.1
Host: api-desarrollo.example.test
Authorization: Bearer <TOKEN_SINTETICO_NO_REAL>
Accept: application/json
```

Los ejemplos ilustran rutas y headers, no prueban que el backend acepte esos cuerpos ni que un usuario particular pueda acceder. **No guardar credenciales reales ni token en Git**.

10. Calidad del contrato y documentación OpenAPI

Inventario de contrato: nombre, versión y servidor; tags por módulo; esquema Bearer; formato uniforme de errores; cuerpos de solicitud/resultado; códigos HTTP; ejemplos sintéticos; filtros, ordenación y paginación; tipos enum; operación idempotente; políticas y rate limits.

Proceso de publicación: compilar API de la rama objetivo → cargar servidor de pruebas → exportar /swagger/v1/swagger.json → validar JSON con linter OpenAPI → comparar con versión anterior → generar colección Postman → pruebas smoke/negative → comprometer artefacto con SHA de backend y fecha.

Cambios compatibles: añadir campos opcionales suele ser menos riesgoso que eliminar campos obligatorios; cambios de tipo, de enums, de semántica financiera o de autorizaciones requieren versionado coordinado con web/móvil. Establecer versiones de cliente que se soportan y política de deprecación.

SignalR: Program.cs mapea /hubs/notifications; documentar eventos y grupos desde NotificationHub.cs, proceso de conexión, autorización, reintentos, throttling y fallback GET. Las notificaciones push dependen de Expo y permisos del dispositivo; no equipararlas a las señales SignalR.

11. Seguridad por endpoint y observación de pagos

BOLA/IDOR: todas las rutas con {id}, orderId, tableId, branchId o customerId deben comprobar titular/sede dentro del servicio. La validación de rol general no es suficiente.

Operaciones administrativas: GET/POST/PUT/DELETE Branches y Products requieren matriz rol × acción × sede, con pruebas para gerente, administrador, cajero y cliente.

Webhook: AllowAnonymous es normal para recepción desde un tercero, pero exige autenticidad criptográfica del payload y correlación de monto/referencia. Wompi recomienda checksum y separación de ambientes; registrar cada evento con estado y evitar aplicar efectos múltiples.

Operaciones de devolución: RefundPayment debe tener razón, usuario y auditoría verificables; mantener constancia de estado externo e interno y no inferir devolución aprobada por HTTP 200 de la API local.

Fuentes primarias de implementación

- API: https://github.com/yersonct/SaborExpressBack/tree/main
- Web: https://github.com/yersonct/SaborExpressWeb/tree/main
- Móvil: https://github.com/yersonct/SaborExpressMovil/tree/main
- Referencia de presentación: https://github.com/jsgh1/SRD-v1/tree/dev/docs/docs-SRD

Control documental: documento elaborado a partir del estado observado en octubre de 2026. Antes de entregar, verificar el commit exacto, responsable, revisión del instructor y cualquier cambio posterior del código.

12. Ejemplos de integración por cliente y controles esperados

12.1 Consulta de productos públicos

```
# API local ilustrativa: el puerto se obtiene de la consola real.
curl -i 'http://localhost:5000/api/Products?branchId=1'
```

El controlador permite consulta anónima, con filtro opcional por sede. Requiere verificar que la respuesta no filtre campos administrativos sensibles y que la sede exista.

12.2 Creación autenticada de pedido

POST /api/Orders HTTP/1.1

Host: localhost:5000

Authorization: Bearer {TOKEN_DE_PRUEBA}

Content-Type: application/json

{ "EJEMPLO_DE_CONTRATO": "El cuerpo debe obtenerse desde CreateOrderDto del SHA revisado" }

El cuerpo anterior **no es un payload funcional**: documenta la necesidad de consultar Modules/Orders/DTOs/CreateOrderDto.cs antes de enviar solicitudes reales. No se inventan nombres de propiedades ni casos aprobados.

12.3 Inicio y confirmación Wompi

POST /api/Payments/wompi/init solicita inicialización; POST /api/Payments/wompi/webhook recibe un evento externo e incluye lectura de cuerpo crudo y X-Event-Checksum; POST /api/Payments/{id}/wompi-sync admite reconciliación. No publicar códigos 200 como éxito de transacción si el servicio aún no ha verificado integridad, referencia y monto. En Postman se deben usar **sandbox y datos sintéticos**.

13. Reglas del catálogo profesional

Cada endpoint debe conservar: método, URL, versión, descripción, actor, permisos, DTO request, ejemplo auténtico, response, tabla de códigos HTTP, errores de dominio, idempotencia, limitaciones de seguridad, evento emitido, caso QA y estado de ejecución. El controlador no basta para completar todos los esquemas de DTO; se requiere exportación Swagger versionada.



Figura 5. Pago digital: flujo y controles recomendados

05_SEQUENCE_PAYMENT

Nota. Elaboración para el estudio de caso SaborExpress; las figuras no certifican operaciones desplegadas.